VAPT Report

Prepared By	C3iHub
Prepared For	CDIS(IITK)
Submission	RT_S1
Tag	High

December 26, 2025

NOTICE: The information provided in this document is CONFIDENTIAL and is intended only for CDIS, IIT Kanpur.

Contents

I SAR Summary **5**

II Vulnerability Description **8**

1 Citizen Consumer Affairs **9**

1.1 SSL Certificate Not Found . . . 10
1.1.1 Narrative . . . 10
1.1.2 Description . . . 10
1.1.3 Impact of vulnerability . . . 10
1.1.4 Proof of Concept . . . 10
1.1.5 Recommended Remediation . . . 11
1.2 Weak JWT Sign Key . . . 12
1.2.1 Narrative . . . 12
1.2.2 Description . . . 12
1.2.3 Impact of vulnerability . . . 12
1.2.4 Proof of Concept . . . 12
1.2.5 Recommended Remediation . . . 13
1.3 Username Enumeration on Login Page . . . 14
1.3.1 Narrative . . . 14
1.3.2 Description . . . 14
1.3.3 Impact of vulnerability . . . 14
1.3.4 Proof of Concept . . . 14
1.3.5 Recommended Remediation . . . 14
1.4 No Rate Limit . . . 15
1.4.1 Narrative . . . 15
1.4.2 Description . . . 15
1.4.3 Impact of vulnerability . . . 15
1.4.4 Proof of Concept . . . 15
1.4.5 Recommended Remediation . . . 15
1.5 Missing Security Headers . . . 16
1.5.1 Narrative . . . 16
1.5.2 Description . . . 16
1.5.3 Impact of vulnerability . . . 16
1.5.4 Proof of Concept . . . 17
1.5.5 Recommended Remediation . . . 17
1.6 TLS Cookie Without Secure Flag . . . 18
1.6.1 Narrative . . . 18
1.6.2 Description . . . 18
1.6.3 Impact of vulnerability . . . 18
1.6.4 Proof of Concept . . . 18
1.6.5 Recommended Remediation . . . 18
1.7 SSH Version Disclosure . . . 19
1.7.1 Narrative . . . 19
1.7.2 Description . . . 19
1.7.3 Impact of vulnerability . . . 19
1.7.4 Proof of Concept . . . 19
1.7.5 Recommended Remediation . . . 19

Assets in scope & Status of Reported Vulnerabilities

Table 1: List of Assets

1	https://citizenconsumeraffairs.com/	7

Table 2: Current Status

1	Vulnerabilities reported earlier	0
1.1	Patched	0
1.2	Carry forward	0
2	New Vulnerabilities	7
3	Total vulnerabilities reported till date	7
4	Total vulnerabilities included in this report	7

List of Symbols for Following Table

S. No.	Symbol	Meaning
1	x	Not patched
2		Not Identified
3		Newly Identified Vulnerability

Total Vulnerabilities Included In This Report			26/12/2025
S. No.	Vulnerability	Vulnerable Link Reported	S1
1	SSL Certificate Not Found	http://13.200.152.212/	
2	Weak JWT Sign	https://citizenconsumeraffairs.com/	
3	Username Enumeration on Log	https://citizenconsumeraffairs.com/	
4	No Rate Limit	https://citizenconsumeraffairs.com/	
5	Missing Security Headers	https://citizenconsumeraffairs.com/	
6	TLS Cookie Without Secure	https://citizenconsumeraffairs.com/	
7	SSH Version Disclosure	https://citizenconsumeraffairs.com/	

Part I

SAR Summary

Severity	Number of Vulnerabilities
Identified	7
Confirmed	7
Critical	0
High	2
Medium	3
Low	2
Informational	0
Best Practices	0

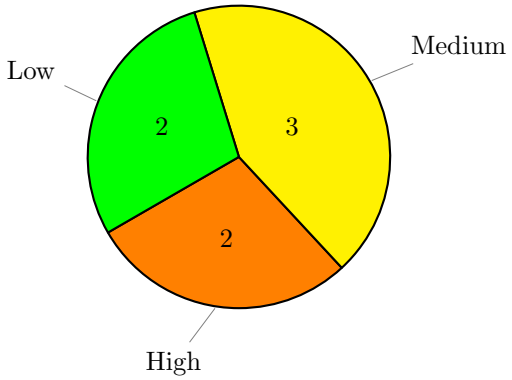


Figure 1: Identified Vulnerabilities

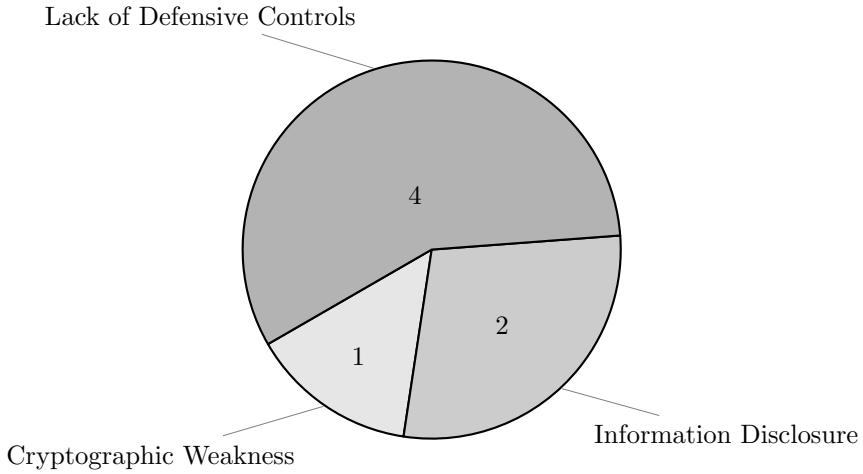


Figure 2: Impact Analysis

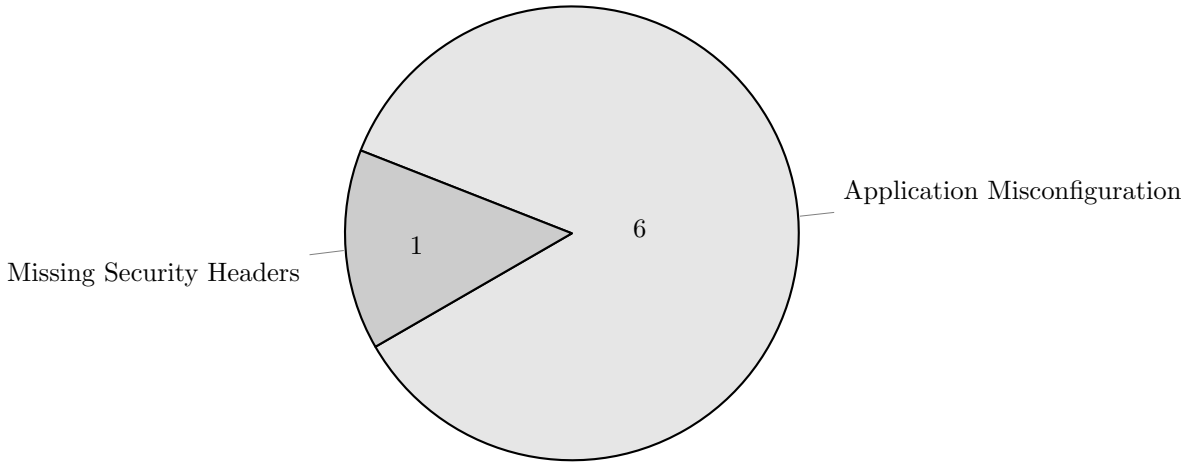


Figure 3: Root Cause Analysis

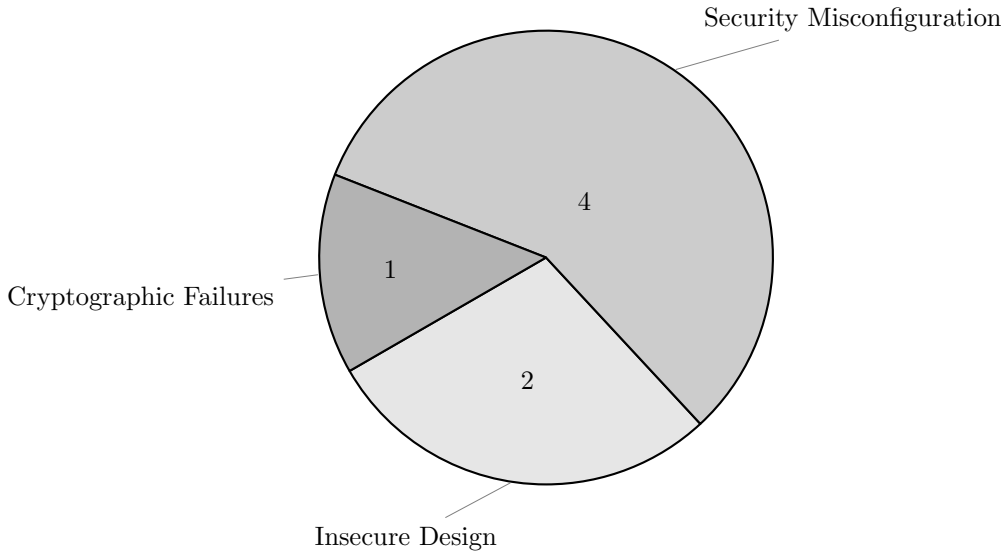


Figure 4: Vulnerabilities by OWASP Top 10

Part II

Vulnerability Description

Asset 1

Citizen Consumer Affairs

Asset Name	https://citizenconsumeraffairs.com/

Severity	Number of Vulnerabilities
Identified	7
Confirmed	7
Critical	0
High	2
Medium	3
Low	2
Informational	0
Best Practices	0

1.1 SSL Certificate Not Found

Refer: Improper Certificate Validation [3]

Target URL	http://13.200.152.212/
Vulnerability Name	SSL Certificate Not Found
Severity	High
Severity score	8.2

1.1.1 Narrative

Attack Vector	Network
Attack complexity	Low
Privilege Required	None
User Interaction	Required
Scope	Unchanged

1.1.2 Description

Refer: Improper Certificate Validation [3]

- The application endpoint was observed to be accessible without a valid SSL/TLS certificate.
- Absence of a trusted certificate prevents secure encryption of data in transit and exposes users to man-in-the-middle attacks.

1.1.3 Impact of vulnerability

Confidentiality	High
Integrity	High
Availability	None

1.1.4 Proof of Concept

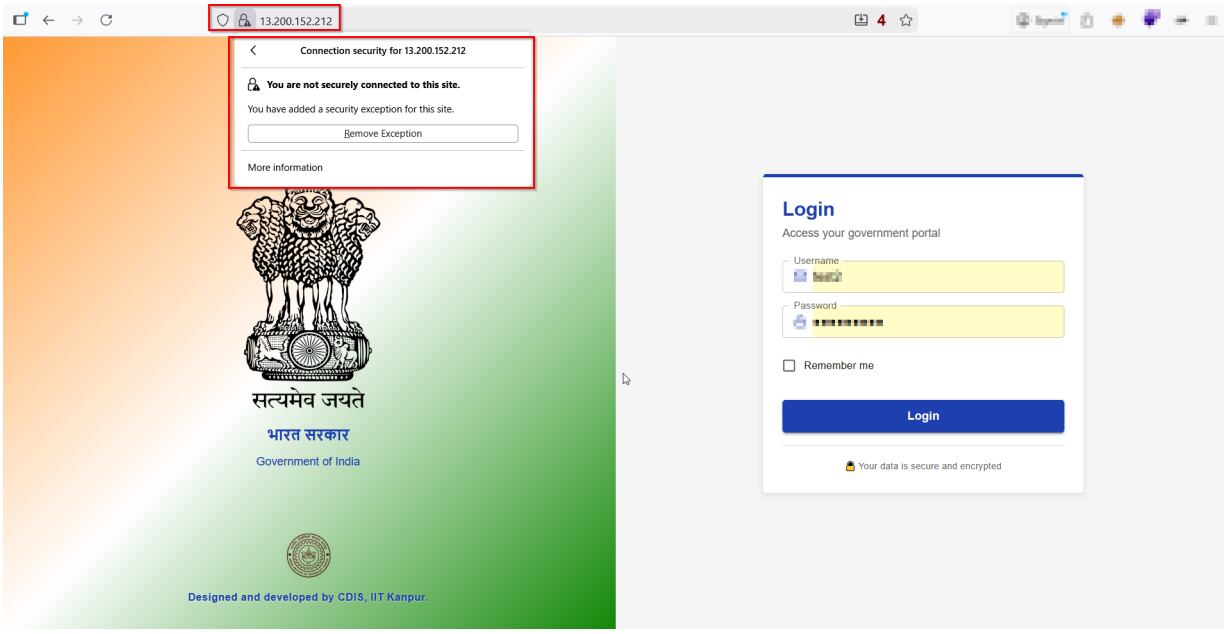


Figure 1.1: SSL Certificate Not Found

1.1.5 Recommended Remediation

- Obtain and install a valid SSL/TLS certificate from a trusted Certificate Authority (CA).
- Enforce HTTPS across the entire application and disable plaintext HTTP access.

1.2 Weak JWT Sign Key

Refer:Inadequate Encryption Strength [4]

Target URL	https://citizenconsumeraffairs.com/
Vulnerability Name	Weak JWT Sign Key
Severity	High
Severity score	7.5

1.2.1 Narrative

Attack Vector	Network
Attack complexity	Low
Privilege Required	None
User Interaction	Not Required
Scope	Unchanged

1.2.2 Description

Refer:Inadequate Encryption Strength [4]

- JSON Web Tokens (JWTs) were observed to be signed using a weak or predictable secret key. An attacker can brute-force or guess the signing key and forge valid tokens.

1.2.3 Impact of vulnerability

Confidentiality	High
Integrity	High
Availability	None

1.2.4 Proof of Concept

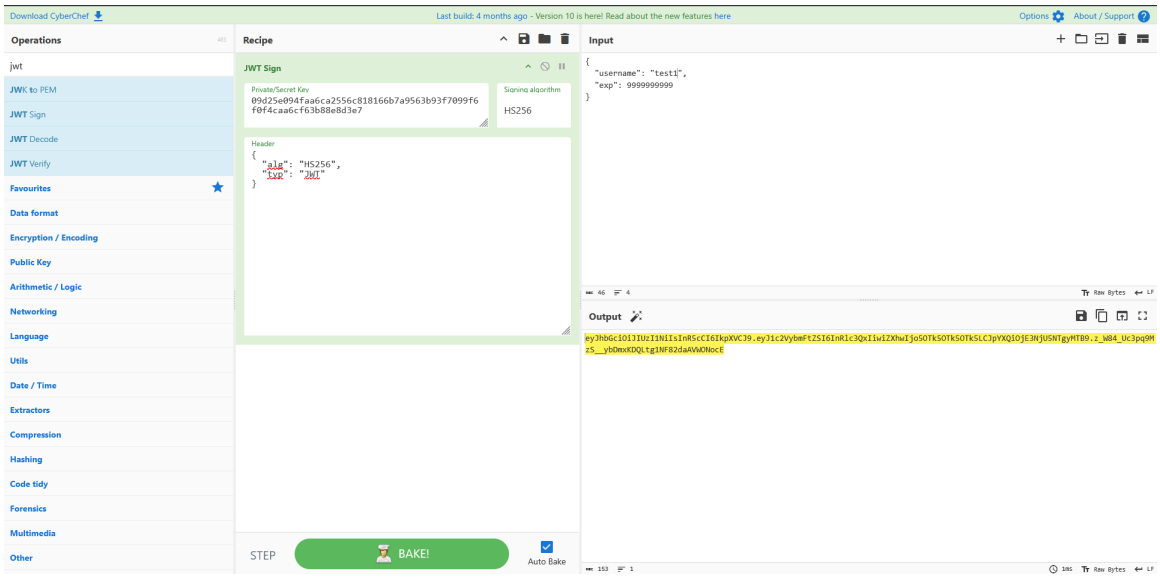


Figure 1.2: Weak JWT Sign Key

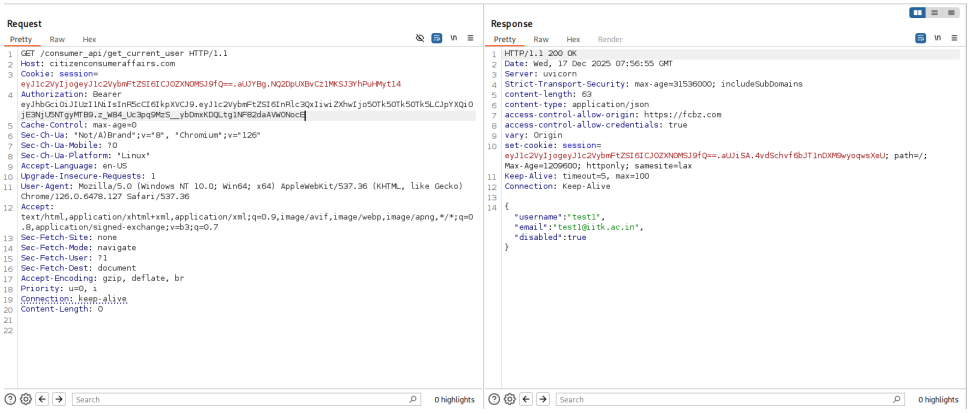


Figure 1.3: Weak JWT Sign Key

1.2.5 Recommended Remediation

- Use a cryptographically strong, randomly generated signing key with sufficient entropy.
- Rotate JWT signing keys periodically and invalidate previously issued tokens.
- Prefer asymmetric signing algorithms (RS256/ES256) over symmetric ones where possible.

1.3 Username Enumeration on Login Page

Refer: Observable Discrepancy [2]

Target URL	https://citizenconsumeraffairs.com/
Vulnerability Name	Username Enumeration on Login Page
Severity	Medium
Severity score	5.6

1.3.1 Narrative

Attack Vector	Network
Attack complexity	Low
Privilege Required	None
User Interaction	Not Required
Scope	Unchanged

1.3.2 Description

Refer: Observable Discrepancy [2]

- The login functionality returns different error messages for valid and invalid usernames.
- This behavior allows an attacker to enumerate valid usernames prior to launching brute-force or password-spraying attacks.

1.3.3 Impact of vulnerability

Confidentiality	Medium
Integrity	Low
Availability	Low

1.3.4 Proof of Concept

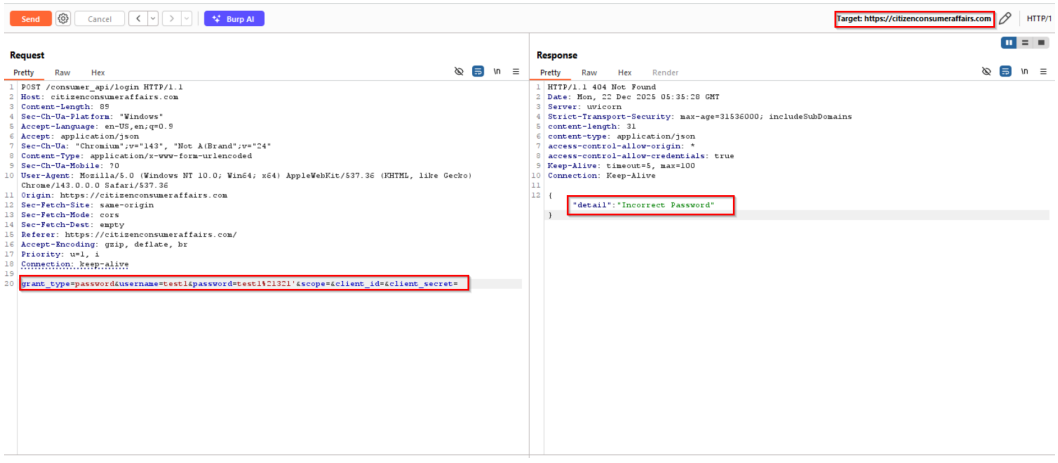


Figure 1.4: Username Enumeration on Login Page

1.3.5 Recommended Remediation

- Use generic and consistent error messages such as “Invalid username or password”.
- Ensure identical response codes and response times for all authentication failures.

1.4 No Rate Limit

Refer: Allocation of Resources Without Limits or Throttling [7]

Target URL	https://citizenconsumeraffairs.com/
Vulnerability Name	No Rate Limit
Severity	Medium
Severity score	5.3

1.4.1 Narrative

Attack Vector	Network
Attack complexity	Low
Privilege Required	None
User Interaction	Not Required
Scope	Unchanged

1.4.2 Description

Refer: Allocation of Resources Without Limits or Throttling [7]

- The application does not enforce rate limiting or request throttling on authentication or sensitive endpoints.
- An attacker can send a high volume of requests to brute-force credentials or exhaust server resources.

1.4.3 Impact of vulnerability

Confidentiality	Low
Integrity	Low
Availability	Medium

1.4.4 Proof of Concept

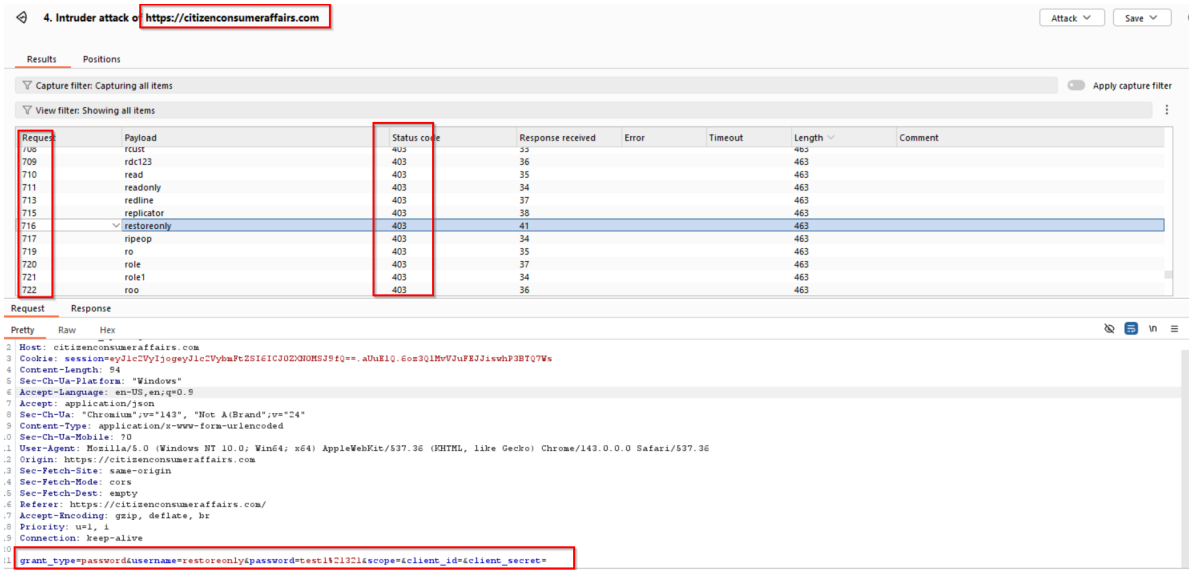


Figure 1.5: No Rate Limit

1.4.5 Recommended Remediation

- Implement rate limiting on authentication and sensitive endpoint.

1.5 Missing Security Headers

Refer: Improper Neutralization of HTTP Headers [6]

Target URL	https://citizenconsumeraffairs.com/
Vulnerability Name	Missing Security Headers
Severity	Medium
Severity score	6.8

1.5.1 Narrative

Attack Vector	Network
Attack complexity	Low
Privilege Required	None
User Interaction	Required
Scope	Unchanged

1.5.2 Description

Refer: Improper Neutralization of HTTP Headers [6]

- The application was observed to be missing multiple recommended HTTP security headers.
- Content Security Policy (CSP) header is not implemented, reducing protection against XSS and data injection attacks.
- Referrer-Policy header is not implemented, leading to potential leakage of sensitive URL information.
- X-Content-Type-Options header is not set, allowing MIME-sniffing attacks.
- X-Frame-Options header is not implemented, exposing the application to clickjacking attacks.
- The application does not redirect HTTP traffic to HTTPS, increasing the risk of man-in-the-middle attacks.

1.5.3 Impact of vulnerability

Confidentiality	Medium
Integrity	Medium
Availability	None

1.5.4 Proof of Concept

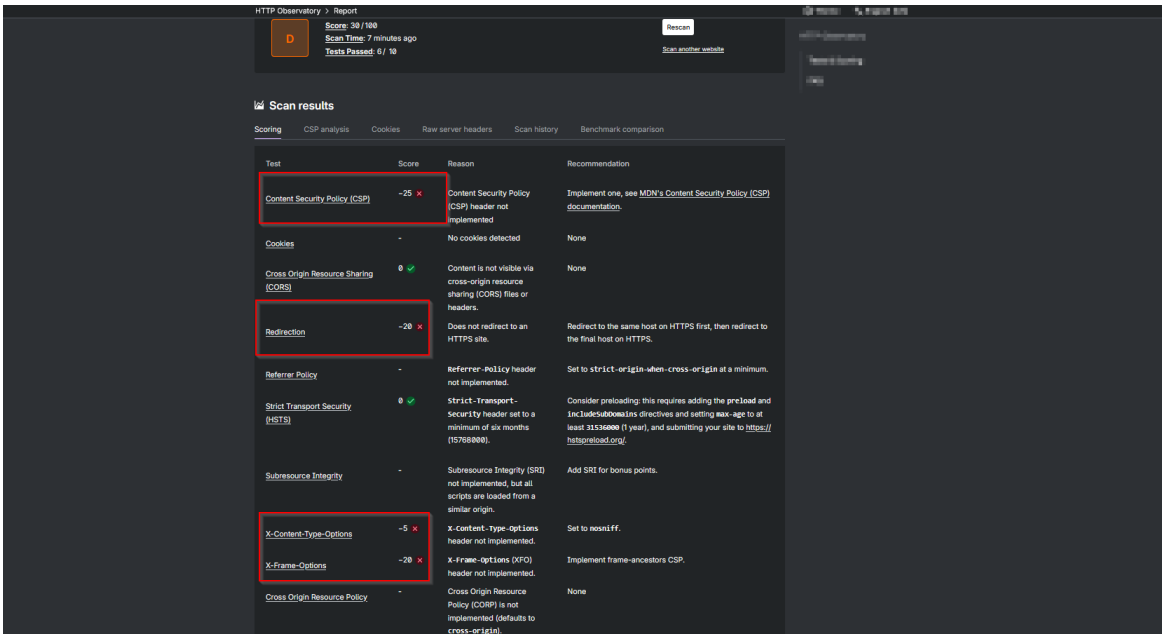


Figure 1.6: Missing Security Headers

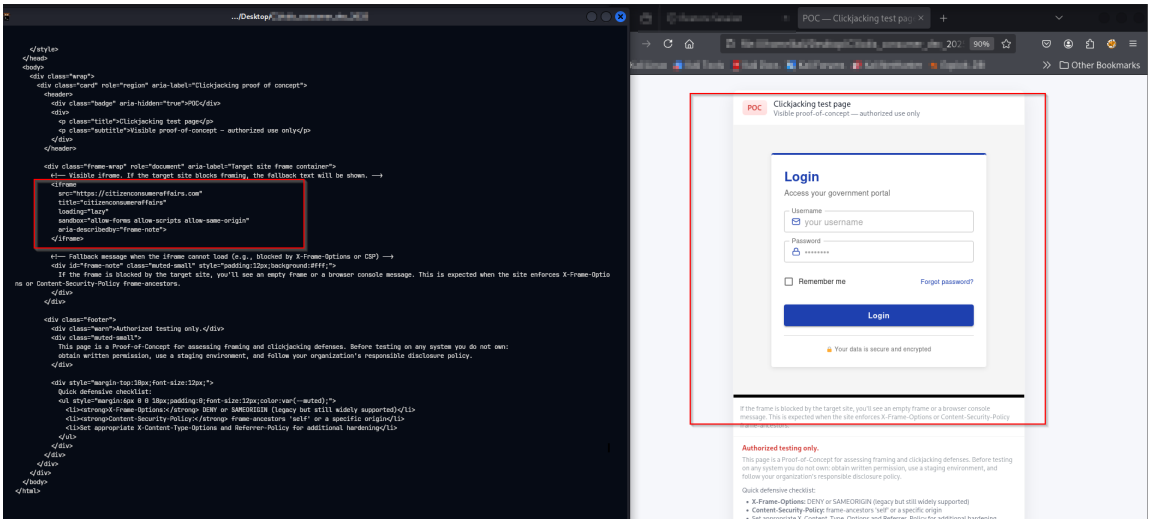


Figure 1.7: Missing Security Headers

1.5.5 Recommended Remediation

- Implement a strong Content-Security-Policy (CSP) to restrict script, style, and resource loading.
- Enforce HTTPS by redirecting all HTTP requests to HTTPS.
- Set Referrer-Policy to `strict-origin-when-cross-origin` or stricter.
- Add X-Content-Type-Options header with value `nosniff`.
- Implement clickjacking protection using CSP `frame-ancestors` directive.

1.6 TLS Cookie Without Secure Flag

Refer: Missing Secure Attribute on Cookie [5]

Target URL	https://citizenconsumeraffairs.com/
Vulnerability Name	TLS Cookie Without Secure Flag
Severity	Medium
Severity score	6.5

1.6.1 Narrative

Attack Vector	Network
Attack complexity	Low
Privilege Required	None
User Interaction	Not Required
Scope	Unchanged

1.6.2 Description

Refer: Missing Secure Attribute on Cookie [5]

- Sensitive cookies were observed without the Secure flag, allowing them to be transmitted over unencrypted connections.

1.6.3 Impact of vulnerability

Confidentiality	Medium
Integrity	Low
Availability	None

1.6.4 Proof of Concept

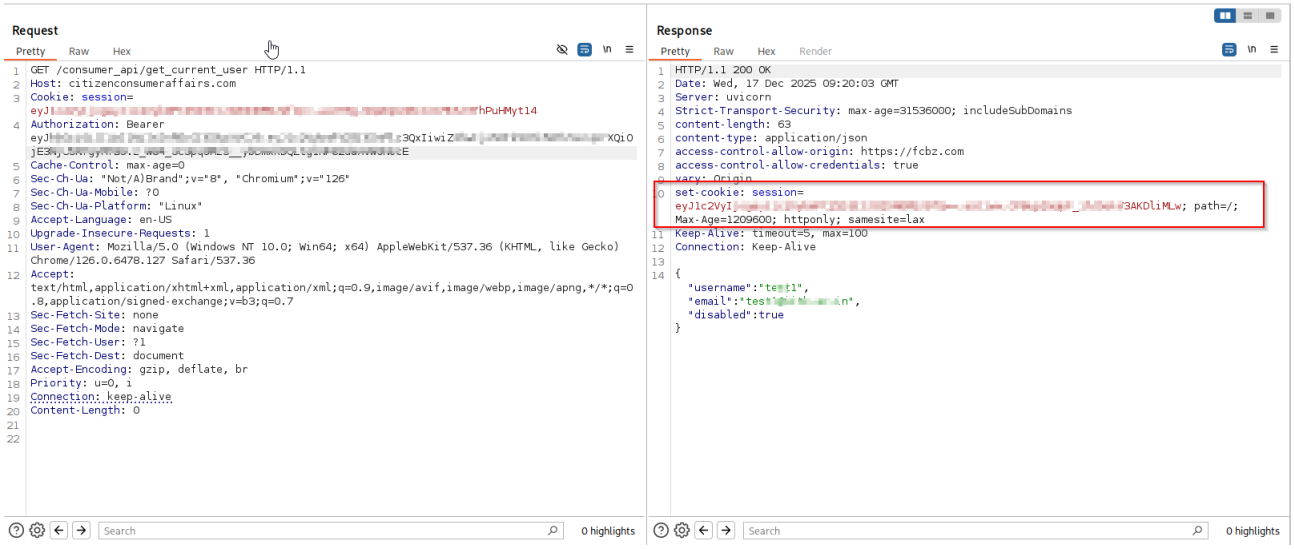


Figure 1.8: TLS Cookie Without Secure Flag

1.6.5 Recommended Remediation

- Set the Secure and HttpOnly attributes on all sensitive cookies.
- Enforce HTTPS across the application.

1.7 SSH Version Disclosure

Refer: Information Exposure [1]

Target URL	https://citizenconsumeraffairs.com/
Vulnerability Name	SSH Version Disclosure
Severity	Low
Severity score	3.7

1.7.1 Narrative

Attack Vector	Network
Attack complexity	Low
Privilege Required	None
User Interaction	Not Required
Scope	Unchanged

1.7.2 Description

Refer: Information Exposure [1]

- The SSH service discloses detailed version information during banner grabbing, which can aid attackers in identifying known vulnerabilities.

1.7.3 Impact of vulnerability

Confidentiality	Low
Integrity	None
Availability	None

1.7.4 Proof of Concept

```
kali@kali:~$ nc 13.200.152.212 22
SSH-2.0-OpenSSH_9.6p1 Ubuntu-3ubuntu13.14
```

Figure 1.9: SSH Version Disclosure

1.7.5 Recommended Remediation

- Configure SSH to hide or minimize version information in banners.
- Regularly update and patch SSH services.

Bibliography

[1] Exposure of sensitive information to an unauthorized actor, . URL https://cwe.mitre.org/data/definitions/200.html.

[2] Observable response discrepancy, . URL https://cwe.mitre.org/data/definitions/204.html.

[3] Improper certificate validation, . URL https://cwe.mitre.org/data/definitions/295.html.

[4] Inadequate encryption strength, . URL https://cwe.mitre.org/data/definitions/326.html.

[5] Sensitive cookie in https session without 'secure' attribute, . URL https://cwe.mitre.org/data/definitions/614.html.

[6] Protection mechanism failure, . URL https://cwe.mitre.org/data/definitions/693.html.

[7] Allocation of resources without limits or throttling, . URL https://cwe.mitre.org/data/definitions/770.html.